What You Sign Is Not What You Run: The Verifiability Gap in Quantized LLM Supply Chains

Wei-Liang Liu
National Yang Ming Chiao Tung University
rlooooong@gmail.com

Cheng-Yen Tsai
National Taiwan University of Science and Technology
nemo00407@gmail.com

arXiv:2610.19498v1 [cs.CR] 14 Oct 2026

***Abstract*—Model signing authenticates the full-precision weights W an LLM is released with, yet users run a *quantized* artifact Q whose producing transformation is not uniquely determined under current disclosure. We separate the non-environment inputs from the execution environment E and measure a quantity that, to our knowledge, has not been measured before: the *Independent Verifiability Rate* (IVR), the fraction of a popularity-sampled GGUF ecosystem that a third party can re-derive bit-for-bit. Across the 200 most-downloaded Hugging Face GGUF repositories (198 in scope), no artifact or model card records the build environment, so under a recorded-inputs protocol the IVR is $0/198$. Yet the artifacts are not irreproducible. On four in-sample repositories that disclose their inputs, the card's information alone reproduces no `Q4_K_M` file, but two coordinates the card omits—the build's floating-point-contraction setting and, for hybrid models, the per-tensor quantization recipe—re-derive $7/8$ target–quant files bit-for-bit on x86 ($5/8$ on arm64); the fp16 re-derives from the provider's checkpoint, but the calibration imatrix must be shipped and hash-bound, since recomputing it did not match. An older release additionally pins the instruction set and did not re-derive. Reproducing the divergence reported with `llama.cpp` PR #25353, we show that E is a necessary coordinate and that one compiler setting yields a unique output across the tested platforms at negligible quality cost ($+0.06\%$ perplexity). As a security characterization, benign floating-point non-determinism separates from uniformly placed nibble-flip tampering above a detection floor that grows with the environments a verifier must allow, but a targeted embedding edit evades the statistic, so the proposed protocol rests on exact re-derivation; adversarial-fp16 attacks lie outside it. We release the audit data and a re-runnable harness.**

I. Introduction

Reproducible builds turned "trust the publisher" into "verify the artifact" [1]. A decade of engineering made over 96% of Debian's packages (bookworm/amd64) *reproducible* in its continuous rebuild tests [2]: building a package twice under deliberately varied environments yields the *same bytes*, so an independent rebuild can be checked against the released artifact. Source authentication thereby becomes an end-to-end integrity check. ML supply chains are adopting the same primitives—model signing (Sigstore Model Signing [3], [4], NVIDIA NGC [5]) authenticates the hashes of the released files, and lifecycle-attestation efforts (the IETF `ai-model-lifecycle-attestation` draft [6], CycloneDX ML-BOM [7]) record provenance.

There is a gap these primitives do not close. Users of local-inference ecosystems typically do not run the signed full-precision weights W; they run a *quantized* artifact Q—e.g. a 4-bit GGUF widely distributed through `llama.cpp` [8]/`ollama` ecosystems. Q is produced by a transformation $\mathcal{T}$ whose inputs go far beyond W: the quantization recipe θ, the calibration input C (an *importance matrix*, "imatrix": per-weight calibration statistics computed by running the model over a corpus), the execution environment E (quantizer release and build, compiler, architecture, floating-point settings), and non-weight components M (tokenizer, chat template, metadata). Writing the non-environment inputs as $\bar{X} = (W, \theta, C, M)$, we observe that under currently disclosed specifications Q is not uniquely determined: signing $H(W)$ says nothing about which Q a user should accept, and re-running $\mathcal{T}$ on a different platform can produce different bytes.

We ask a question that, to our knowledge, the ML supply chain has not measured: *of the GGUF repositories in our popularity-sampled ecosystem, what fraction expose an artifact that a third party can independently re-derive bit-for-bit?* We call this the Independent Verifiability Rate,

$$\text{IVR} = \frac{\#\{\text{bit-exact re-derivable artifacts}\}}{\#\{\text{evaluated artifacts}\}}.$$

We fix IVR to bit-exact re-derivability; attestation-based binding (e.g. by a Trusted Execution Environment, TEE: hardware that signs a statement of which binary ran on which inputs) is a separate mechanism (§VII), not part of this metric.

a) Our answer, under a recorded-inputs protocol, is $0/198$: None of the 198 in-scope repositories among the 200 most-downloaded exposes enough to satisfy our re-derivation protocol. That means the disclosed inputs are insufficient for *our* verifier, not that the artifacts are mathematically unreproducible. Part of this is structural: GGUF has no field for the build environment, so the metadata half of our checklist cannot pass, and the census measures what the format and current disclosure practice allow; the model-card scan and a re-derivation attempt test whether disclosure elsewhere closes the gap. A verifier can also succeed by *searching* environments instead of reading a record; the trial of §IV shows this works for recent releases on the publisher's architecture and fails for an older one, so the search-based rate is not zero but is

unmeasured beyond our trial. We then explain *why*, *what it costs*, and *how to close it*, as three measurements feeding a verification protocol (Figs. 1–3):

- **M1 (§IV):** the recorded-inputs IVR is $0/198$; no artifact or model card records the build environment—compiler, architecture, floating-point settings (19/198 cards do state the `llama.cpp` release). On four in-sample repositories, re-deriving the deployed files from the card's disclosed inputs (release, publisher's own fp16, imatrix, stock preset) reproduces none of the `Q4_K_M` files. Supplying two coordinates the card omits—the build's FP-contraction setting and, for hybrid models, the per-tensor recipe—re-derives $7/8$ target–quant files bit-for-bit on x86, and for a pilot repository the fp16 itself re-derives bit-for-bit from the provider's checkpoint.
- **M2 (§V):** reproducing the floating-point-contraction divergence reported with PR #25353, we find the execution environment E empirically necessary under the studied model; one compiler setting attains $B{=}0$ for the tested types across the tested architectures and compilers at negligible measured quality cost (ΔPPL $+0.06\%$), yet is not the `llama.cpp` default, and the divergence lives in the weight representation, not inert metadata.
- **M3 (§VI):** a security *characterization*—our evaluated statistics separate benign floating-point non-determinism from uniformly placed nibble-flip tampering above a detection floor that grows with the range of build environments a verifier must allow (up to about 0.2% of weights under our five-pair calibration, and more as that range widens); a targeted embedding edit evades them, and adversarial-fp16 attacks lie outside re-derivation.
- **Protocol (§VII):** An ambiguity-free transformation ($B{=}0$) is the natural precondition for trustless re-derivation; uniform partial spot-checking against an m-unit tampering within N units needs $\Theta(N/m)$ openings to hold a fixed detection probability.

b) Contributions: (i) To our knowledge, the first popularity-sampled measurement of GGUF independent verifiability, decomposed into what is *obtainable* (source-reconstructible, $148/198$) versus what is *recorded* (the build environment: $0/198$, a structural consequence of the format having no field for it). The constructive core of the paper is a trial re-derivation on named public artifacts (five repositories across three model families and three releases, `b3772`–`b10603`): it locates the failure in the quantization step and names the card-absent coordinates that close it. With those supplied, $7/8$ target–quant files of the four Qwen repositories and both files of the Granite one re-derive bit-for-bit, and for a pilot repository the fp16 already re-derives from the provider's checkpoint. (ii) A compact vocabulary—$\bar{X}/E$, the admissible set $\mathcal{A}$, and a $0/1$ ambiguity indicator B—that makes precise what a complete re-derivation specification must fix; under it the necessity of recording the environment E is immediate, and we witness it empirically (§V). We use this as scaffolding for the measurements, not as a result in itself. (iii) A security characterization of the $B{>}0$ regime: how much one-step tampering hides in benign environment variation (up to about 0.2% of weights under our five-pair calibration, growing with the range of environments allowed), what a max statistic adds against sparse large edits, and a delineated threat boundary. In our sweeps, a uniform scale perturbation is caught before it is harmful and adaptive placement hides only a bounded low-magnitude reservoir, but a *targeted* embedding attack evades the statistic (§VI); this is why the protocol relies on exact re-derivation rather than detection. Along the way we independently reproduce the floating-point-contraction divergence of PR #25353, add a weight-space localization and a size trend, and confirm its perplexity report with a paired estimate. We also provide a re-runnable audit harness and our analysis tools (GGUF header-probe, byte-region diff, and detector), distinct from the external re-derivation engine we instrument.

c) Prior art we build on, not claim: Deterministic GGUF re-derivation is existing engineering (ggufpacker, which pins and packages quantization inputs, publishes cross-machine bit-exact derivation attestations for quants built with the fix, and reports that for quants built before it `Q8_0` packs are exact while most k-quants need a correction delta and cannot be attested [9]; llama.cpp PR #25353 [10]), as is the observation that k-quant outputs diverge across platforms because of floating-point contraction. The adversarial-fp16 attack that bounds our threat model is also prior work (Mind the Gap [11]). Our contribution is to *measure* how far current disclosure falls short of what these tools presuppose, *name* what a manifest must bind for re-derivation to succeed, and *delineate* what re-derivation can and cannot cover. The trial re-derivation (§IV, Table III) also makes explicit a coordinate that a packager pins silently: on named public artifacts, the card's quant type ("`Q4_K_M`") underdetermines the publisher's *per-tensor recipe*, a discrete input that the card does not disclose and that no stock preset regenerates; it must be supplied alongside the environment before re-derivation succeeds.

II. Background & Threat Model

a) Reproducible builds: The reproducible-builds movement made the integrity of a running binary independently checkable: recompile from source in a recorded environment and confirm bit-for-bit that it matches the shipped binary, supported by tooling that locates non-determinism (`diffoscope` [12], `reprotest` [13]) and a network of independent rebuilders. Much of the residual non-determinism it confronts is *normalizable metadata*—embedded timestamps, build paths, filesystem ordering, locale—which is canonicalized away; for the rest of the build environment, the practice is to either make it irrelevant to the output or record it so the artifact can be rebuilt exactly (e.g. Debian's `.buildinfo` files) [14]. A central empirical question of this paper is how quantization fares under this recipe. Normalization cannot help—the non-determinism lies in the numeric content of the weights (§V)—so the environment must be made irrelevant (one compiler setting achieves this on the tested platforms,

§V) or recorded, which no artifact in our sample fully does (§IV).

b) Model signing & attestation: The ML ecosystem is adopting the signing half of this picture. Sigstore Model Signing [3], [4] and NVIDIA NGC [5] sign a manifest of the released files' hashes (the weights W and whatever else the repository ships), binding an artifact to a publisher's identity. Provenance and lifecycle efforts go further in describing the pipeline: the IETF `ai-model-lifecycle-attestation` draft (an individual Internet-Draft) [6] records a source-weight hash, a quantized-artifact hash, a quantization-tool hash, and per-layer error tolerances (a check of the kind a sub-threshold targeted edit evades, §VI); CycloneDX ML-BOM enumerates model components [7]; and work on attesting LLM pipelines gates artifact promotion on verifiable training and release claims [15]. None of the specifications we examine requires binding the calibration input C (the imatrix) as an input of the quantization (a file-manifest signature covers an imatrix the repository happens to ship, but does not tie it to the artifact derived from it), and E is bound at most indirectly: a hash of the quantization tool identifies the quantizer binary but does not describe it, so a verifier on another platform cannot recreate an equivalent build. These claims establish provenance and tool identity, but do not by themselves let an independent verifier establish that the artifact is the faithful output of the signed source.

c) The transformation: A deployed GGUF is $Q = \mathcal{T}(\bar{X}; E)$, where $\bar{X} = (W, \theta, C, M)$ collects the weights, recipe, calibration input, and non-weight components, and E is the environment. The calibration input is itself a pipeline output, $C = \mathcal{C}(W, D, E_C)$ over a calibration corpus D and its own environment E_C, which is why binding C by hash (as we recommend) matters. Deterministic re-derivation of GGUF outputs is existing engineering—ggufpacker [9] packages the inputs, and `llama.cpp` [8] PR #25353 [10] removes a floating-point non-determinism—and we use these as an *instrument* to measure the boundary they presuppose, not as a contribution we claim. Throughout, W denotes the full-precision artifact actually fed to $\mathcal{T}$—for GGUF, the publisher's released fp16 GGUF; the upstream conversion of the provider's checkpoint to fp16 is a separate transformation stage, which we test once (§IV) and otherwise leave out of scope.

d) Block quantization in one paragraph: A GGUF k-quant [16] stores weights in fixed-size blocks, grouped into 256-weight *superblocks*: each block holds low-bit integer codes for its weights—4-bit codes are packed two per byte as *nibbles*—plus per-block *scale* (and minimum) parameters, so that a dequantized weight is approximately scale $\times$ code and the spacing between adjacent representable values (one *quantization step*) is set by the scale. The scales are not read off directly: a small floating-point optimization (the *scale search*) picks the scale minimizing the block's reconstruction error, weighted by the imatrix when one is supplied. Two consequences carry the rest of the paper: the scale search is where floating-point environment differences can change the chosen scales and hence the stored bytes (§V), and altering a stored code moves the corresponding weight by at least one step, whereas perturbing a scale moves every weight in its block by sub-step amounts (§VI).

TABLE I
SECURITY CLAIM BY REGIME. A *cheating quantizer* STARTS FROM A BENIGN W BUT SHIPS $Q \neq \mathcal{T}(\bar{X}; E)$; $B_{\mathcal{E}'}=0$ MEANS THE HONEST OUTPUT IS UNIQUE OVER THE ENVIRONMENTS REBUILDERS USE (§III).

Threat and regime	What re-derivation gives a verifier
Cheating quantizer, $B_{\mathcal{E}'}=0$	Sound detection: a hash mismatch implies tampering, with no false positives (A2, A4).
Cheating quantizer, $B_{\mathcal{E}'}>0$	A nonzero diff no longer implies tampering; uniformly placed nibble flips are only *characterized*, by a measured detection floor, and a targeted edit can evade the statistic (§VI).
Cheating quantizer via C (a chosen imatrix, $Q=\mathcal{T}$)	Nothing beyond binding: the manifest fixes which C was used and re-derivation reproduces Q; vetting C is outside re-derivation (§II).
Malicious W (adversarial fp16, $Q=\mathcal{T}$)	Nothing: the quantization is honest, so re-derivation reproduces the artifact (out of scope, A1).

e) Threat model: In the signed supply chain that model-signing efforts target, the model provider signs $H(W)$, while a quantizer—usually a *different*, third party—publishes Q and implicitly asserts $Q = \mathcal{T}(\bar{X}; E)$; the current ecosystem does not generally provide an independently verifiable cryptographic binding between the signed source and the transformation result. The recommended protocol we analyze (§VII) addresses this gap by having the transforming party sign a manifest committing to the inputs it used, $(H(W), \theta, C, E, M)$, so that any third party can recompute and check. The manifest binds Q to the inputs the transforming party commits to, and for GGUF that party usually supplies three of them itself: W (its own fp16 conversion), C (its own imatrix), and M. Re-derivation therefore certifies the fp16$\rightarrow Q$ step. The conversion that produced W and M can be re-derived too—for the pilot repository of §IV we reproduce the published fp16 bit-for-bit from the model provider's checkpoint—which extends the chain to the provider's weights; a committed C, however, shows which imatrix was used, not that it is benign. Our security claim is regime-split (Table I); Appendix B states the assumptions A1–A7 and the exact boundary of the claim.

f) Why not simply sign Q: A natural objection is that the quantizer could simply sign $H(Q)$. This proves *provenance*—that Q came from whoever holds the signing key—but not *faithfulness* to the signed source W: a cheating quantizer signs its own backdoored Q just as validly, and, because the quantizer is usually not the party that signed W, no signature links the two. Binding Q to W requires *recomputing* Q from W and comparing hashes over the verifier's own recomputation. This is why $B=0$ matters: when two honest recomputations of the same inputs can diverge, there is no canonical $H(Q)$ for a verifier to compare against, and a

signature over one particular Q does not, by itself, establish faithfulness to W.

III. Transformation Ambiguity

Both the measurement (§IV) and its explanation (§V) need one piece of vocabulary, which we fix before turning to the data. Split non-environment inputs from the environment: $\bar{X} = (W, \theta, C, M)$, full input $X = (\bar{X}, E)$, with E ranging over $\mathcal{E}$, the space of admissible execution environments. The admissible-output set is $\mathcal{A}(\bar{X}) = \{\mathcal{T}(\bar{X}; E) : E \in \mathcal{E}\}$ and the ambiguity budget $B(\bar{X}) = \sup_{Q_1, Q_2 \in \mathcal{A}(\bar{X})} d(Q_1, Q_2)$, where d is the discrete metric on serialized artifacts (d=1 iff the bytes differ), so $|\mathcal{A}(\bar{X})|$=1 $\Leftrightarrow$ B=0—exactly the uniqueness of $H(Q)$ that hash comparison requires; under this metric B is simply a 0/1 indicator of non-uniqueness. The same supremum over a subset $\mathcal{E}' \subseteq \mathcal{E}$ defines $B_{\mathcal{E}'}(\bar{X})$: disclosing a coordinate of E shrinks the environments a verifier must consider, so what verification needs is $B_{\mathcal{E}'}$=0 over the environments rebuilders actually use—met by exactly replicating a fully recorded E, or, portably, by a setting under which all of them agree. When we say a setting "attains B=0" we mean $B_{\mathcal{E}'}$=0 for $\mathcal{E}'$ the tested platforms with that setting; Observation 1 concerns the full $\mathcal{E}$. (Where the *size* of a divergence matters rather than its existence, §VI measures perturbations in dequantized weight space.) We write X^* for a *minimal complete specification*—a smallest set of disclosed coordinates making the output unique ($|\mathcal{A}|$=1); Observation 1 shows every complete specification must constrain E, which we abbreviate $E \in X^*$; characterizing X^* in full is left open. The *natural-variance distribution* $\mathcal{R}_{\text{nat}}$ denotes the empirically characterized distribution of weight perturbations induced by benign variation in E. An observation (Observation 1, necessity of E, §V) and a standard sampling bound (Proposition 1, §VII) are stated where they do work; proofs are in Appendix A.

IV. M1: The Independent Verifiability Rate

We operationalize the question of §I as a measurement over the artifacts people actually download.

a) Definitions: An artifact Q is *bit-exact verifiable* if an independent party, given only the disclosed inputs, can recompute a Q' with $H(Q') = H(Q)$; the IVR is the popularity-sampled fraction of deployed artifacts that are. Verifiability is a property of *disclosure*, not of the artifact in principle: a Q that could in fact be reproduced, were its producer to reveal $(\bar{X}, E)$, still counts as non-verifiable while that disclosure is absent. Our census scores a *recorded-inputs* protocol: all four inputs, including the environment, must be disclosed, so that a mismatch is attributable. A verifier may instead *search* plausible environments and accept a hash match; that route needs no record, and the trial below bounds it from below. To separate "the inputs are hidden" from "the environment is hidden," we additionally report the weaker *source-reconstructible* rate—whether the weights W and calibration input C are retrievable at all, ignoring E. Throughout, for GGUF we take W to be the publisher's released fp16 GGUF (the full-precision artifact that is fed to quantization). For the source-reconstructible rate we report two rules: whether the repository ships such a GGUF, and whether its declared base-model repository holds public full-precision weights. The transformation we re-derive and verify is the quantization step fp16 $\to Q$, not the upstream conversion of an original framework checkpoint to fp16, which is a separate stage outside our scope.

b) Sampling frame: Verifiability is not uniform over a randomly chosen model; what matters is what users run, so we sample by popularity. We take the 200 most-downloaded GGUF repositories returned by the Hugging Face API (August 2026, sorted by the API's download count, a trailing 30-day window); two expose no GGUF weight file and fail inclusion, which fixes the denominator at 198 repositories (from 61 distinct publishers), each scored on one representative deployed artifact (below). Because download rankings drift, we freeze the exact repository list and ship it, with the scored snapshot, in the artifact. The scoring is a re-runnable audit (`census.py --repos-file`) that re-scores the frozen list against live metadata, so that a reviewer can check the $0/198$ rather than trust it (repositories change over time, so a re-run may drift from the snapshot).

c) Instrument: Downloading 198 multi-gigabyte repositories is unnecessary: what decides verifiability lives in the GGUF header and the repository's advertised provenance. For each repo we query the HF API for the file inventory, select one representative deployed artifact (preferring its `Q4_K_M` file; the first shard for sharded models), and fetch only that GGUF's header via HTTP range requests (8–16 MB rather than the full file) to parse its key–value block. We then score a four-input re-derivation checklist: (i) is the fp16/source W retrievable; (ii) is the quantizer and its *version* recorded; (iii) is the calibration imatrix C present and retrievable (tri-state: an artifact with no imatrix record is treated as $C = \varnothing$, i.e. fully disclosed rather than a gap—an assumption that misclassifies an imatrix whose record was removed with `--hide-imatrix`); (iv) is any execution-environment coordinate E recorded. No standardized GGUF field carries either the quantizer version or an environment coordinate (`general.quantization_version` records the revision of the quantization format, not the `llama.cpp` build), so from metadata checks (ii) and (iv) are scored jointly as a single environment/version record (the "env/version" bar of Fig. 1b); the model-card analysis below separates them. Bit-exact verifiability requires all four; source-reconstructibility requires only (i) and (iii). For the studied quantization step, these checks cover the inputs our re-derivation procedure consumes. The recipe θ is the quant type named in the artifact (its per-tensor types are recorded in the header) plus options that default per release, the release being part of E in our model. The non-weight components M (tokenizer, chat template, metadata) are taken verbatim from the published GGUF container, whose metadata region an environment rebuild reproduces bit-identically apart from the local file paths that `llama-quantize` records for an imatrix (below and §V). The quantizer does write *into* that block: $62/198$

artifacts carry `quantize.imatrix.*` provenance keys—which is also how the census detects imatrix use, alongside the repository file listing—but these record C-side provenance and no E coordinate. We treat C as an *obtained* input (retrievable or not); verifying its own generation ($C = \mathcal{C}(W, D, E_C)$, §II) is a separate stage outside this measurement.

d) Result: $\mathrm{IVR} = \mathbf{0/198}$ *under the recorded-inputs protocol:* No repository in the frozen set satisfies the recorded-inputs protocol. The source-reconstructible rate is far higher—$148/198$ (74.7%) under the census's rule, which credits public full-precision weights in the declared base-model repository (an upper bound: for a fine-tuned derivative that is the parent model), or $111/198$ (56.1%) if we require the repository itself to ship a full-precision GGUF. For roughly half to three quarters of these models, then, the weights and calibration data are in principle obtainable; what is missing lies elsewhere. The universal gap is the execution environment: no standardized GGUF field records the `llama.cpp` version, compiler, target architecture, or FP-contraction setting, and $0/198$ artifacts record any E coordinate in metadata (19 cards state the release in prose, below). Table II decomposes the result (Fig. 1b plots the first half). Beyond the environment/version record that all 198 lack, 50 repositories also fail source reconstruction; the remaining 148 are missing *only* that record. The environment is thus not one gap among several but the universal one, by construction of the format. For the 154 artifacts whose representative file is a ggml scale-search k- or i-quant, the mechanism of §V is expected to apply—every scale-search type we tested diverged under default builds, though some of these files come from other ggml-based tools we did not test—so the missing record is not a bookkeeping omission: a rebuild in an unrecorded environment can byte-differ from the honest output, and a mismatch cannot then be attributed (the trial below shows both outcomes). For the other 44 (23 `Q8_0`/`Q4_0` files—`Q8_0` matched across our platforms at `b10448`, while `Q4_0` quantized with an imatrix uses a weighted scale search we did not test; 8 f16 or vision-projector files our selector picked where no quantized language-model file was preferred; and 13 custom or mixed-precision formats), the necessity of E is not established, and $\mathrm{IVR} = 0$ reflects the protocol's requirement of a recorded release and environment rather than a demonstrated barrier. Restricting to text and multimodal LLMs leaves the result unchanged ($0/165$). Read the other way, the search-based rate is not zero: in the trial below, three in-sample `Q4_K_M` files re-derive bit-for-bit from disclosed inputs alone on the publisher's architecture, so at least $3/198$ representative files are re-derivable by a verifier willing to guess the environment; measuring that rate across the ecosystem requires re-deriving every obtainable repository, which we leave open.

e) Model cards: A metadata checklist could miss provenance stated in prose (model-card completeness on Hugging Face is known to be uneven [17]), so we checked the human-written model cards in two ways. First, an adversarial audit of 12 cards, selected from the top-60 census stratum as the nine highest-download repositories whose only gap is the environment/version record plus three with deeper gaps. One independent LLM agent per card was instructed to *refute* the "not verifiable" label by finding a disclosed exact quantizer version, build flags, or environment coordinate (a card saying merely "quantized with `llama.cpp`" does not count); the agent saw the scorer's label, which may anchor it, whereas the deterministic scan below does not depend on it. It confirmed $12/12$ (on source availability it disagreed with the scorer for three repositories, two in one direction and one in the other, which we report but do not apply); none of these 12 cards states an exact `llama.cpp` version, one states partial build flags, and several advertise a *custom* quantizer. Second, because a 12-card sample can miss publisher-specific conventions, we pattern-scanned all 198 cards for release and commit identifiers and manually classified every hit: $19/198$ cards—18 of them from two publishers' standard templates, and none from a publisher in the audited sample—state the `llama.cpp` release used for quantization. The scan finds no card stating a compiler, target architecture, or FP-contraction setting (60 cards mention platforms such as Apple Silicon, Metal, or AVX; on manual review all refer to inference or performance, none to the quantization build). The quantizer release is thus sometimes disclosed in prose; beyond one card's partial build flags, the build environment is disclosed nowhere we look. We scope the finding precisely: the build coordinates of E are absent from the GGUF metadata and the model cards of all 198 artifacts—"absent in the locations we audit," not a claim that the producer never possessed it.

f) Source availability is not verifiability—and what closes the gap: The gap is not merely bureaucratic, and these artifacts are not irreproducible: what is disclosed is insufficient, and we can say exactly what is missing. We take four in-sample `bartowski` repositories—`Qwen2.5-7B-Instruct` (release `b3772`) and `Qwen3.5-{0.8B,2B,4B}` (release `b9222`)—each of which publishes its own full-precision GGUF, its imatrix, and `Q4_K_M`/`Q8_0` files, and whose card names the `llama.cpp` release used. From exactly those disclosed inputs we re-derive the deployed files, comparing per-tensor `sha256` of the tensor data (Table III); the key–value region is excluded because `llama-quantize` writes

TABLE II
CENSUS DECOMPOSITION OVER THE 198 REPOSITORIES. RESTRICTING TO TEXT AND MULTIMODAL LLMS BY HUGGING FACE PIPELINE TAG (EXCLUDING SPEECH, VIDEO, IMAGE-GENERATION, EMBEDDING, AND CLASSIFICATION MODELS) LEAVES $\mathrm{IVR} = 0/165$.

What the repositories lack	
Environment/version record	198
Retrievable fp16 source (base-model rule)	33
Retrievable imatrix (2 also lack fp16)	19
Only the environment/version record	148
Representative file scored	
Scale-search k/i-quant	154
`Q8_0`/`Q4_0` (no scale search without an imatrix)	23
f16 or vision projector	8
Custom or mixed-precision format	13

the local imatrix path into it (above), which a whole-file hash would need canonicalized. With only the card's information—the named release, the published imatrix, the stock preset—no `Q4_K_M` file re-derives, and only a minority of its tensors match ($140/335$ and $141/339$ for the two families); the one file among these eight that does re-derive from the card alone is the dense 7B's `Q8_0`, whose stock preset equals the publisher's recipe. The gap decomposes into two coordinates the card never records, neither of which is the weight data. **(1) The per-tensor recipe:** for the hybrid Qwen3.5 models the stock `Q4_K_M` preset does not reproduce the publisher's type map, which keeps the SSM tensors at F32 and bumps others to `Q5_K`/`Q6_K`/`Q8_0` (75–100 tensors differ), though the card records only "`Q4_K_M`". Pinning the published types (a few hundred discrete labels) closes this; for the dense 7B the stock preset already matches, and no recipe is needed. The recipe gap spans the publisher's whole lineup: for the 0.8B, re-deriving *all 23* published quant types—k-quants, legacy quants, i-quants, and the embedding/output-override variants—reproduces $0/23$ from the card's named type alone but $23/23$ bit-for-bit once the recipe is supplied (on x86, whose default build is uncontracted). The pattern is not specific to this family or release. A model from a different provider and family, `granite-4.2-3b` (IBM Granite, a distinct architecture, quantized by the same publisher at the newer release `b10603`), reproduces its `Q4_K_M` in only $263/363$ tensors from the card alone but $363/363$ bit-for-bit with the recipe; there the publisher bumps the attention tensors to `Q5_K`/`Q6_K`, a different hidden recipe from Qwen3.5's F32-kept SSM tensors. Its `Q8_0` reproduces from the card alone. **(2) The build's floating-point contraction**, which is architecture-conditioned: with the recipe pinned, the Qwen3.5 `Q4_K_M` re-derives *bit-for-bit* on x86 (default *and* `-ffp-contract=off`) and on arm64 with `-ffp-contract=off`, but not on an arm64 default build. At `b9222` the quant kernels are compiled portably, so baseline x86-64 (no FMA) is uncontracted by default, while arm64 (NEON FMA, contracted by clang's default) needs PR #25353; once contraction is off the `Q4_K_M` output is bit-identical across the two architectures. With both coordinates supplied, $7/8$ of the target×quant files re-derive bit-for-bit on x86, and $5/8$ on arm64: the 0.8B and 2B `Q8_0` keep one residual tensor there whose all-zero blocks store byte-different but numerically identical codes (the arm64 and x86 kernels round $0/0$ differently), a residual that contraction does not touch—bit-exactness is strictly stronger than numerical equality, and a cross-architecture rebuilder must record the architecture or canonicalize zero blocks. The exception is the 7B `Q4_K_M`: its release `b3772` compiles the quant kernels with `-march=native`, so the environment additionally pins the SIMD ISA, and it matches none of our six configurations (two compilers on arm64 and one on x86, each with contraction on and off; best $170/339$). We did not find the publisher's environment; a different compiler version or build host may add coordinates beyond the ISA. A pilot on a further repository from the same publisher (below the census's download cutoff), `Qwen2.5-1.5B-Instruct` (also `b3772`), behaved the same way: its four rebuilds (two platforms, two builds, with its published imatrix) gave three distinct honest outputs, none matching the published file. The conversion hop, by contrast, re-derives exactly: for that 1.5B repository, converting the model provider's checkpoint (safetensors and model card, Hugging Face revision `989aa79`) with the named converter reproduces the published fp16 bit-for-bit, on a different machine and twice over (the newer converter at `b10448` reproduces the tensor data but writes different metadata); we verified this hop on that one repository only. Given those disclosed inputs, the failure to verify sits in the quantization step, and is localized to a few coordinates the model card does not disclose: for a recent release, the build's contraction setting (for which the GGUF container has no field) and the per-tensor recipe (present in the deployed file's header, but not regenerated by the card's named preset), both small and disclosable. An older release additionally pins the instruction set, and, as the next paragraph shows, the calibration input must be obtained and hash-bound rather than recomputed.

TABLE III

TRIAL RE-DERIVATION: PER-TENSOR BIT-EXACT MATCHES (TENSOR COUNT IN PARENTHESES). *card*=NAMED RELEASE + PUBLISHED IMATRIX + STOCK PRESET; +*rec*=CARD PLUS THE DEPLOYED FILE'S PER-TENSOR TYPE MAP. ON X86 THE DEFAULT BUILD IS ALREADY UNCONTRACTED, SO ITS TWO BUILDS COINCIDE. *=FULLY BIT-EXACT; —=THE STOCK PRESET ALREADY EQUALS THE RECIPE; †=ONE RESIDUAL TENSOR WHOSE ALL-ZERO BLOCKS STORE BYTE-DIFFERENT, NUMERICALLY IDENTICAL CODES; ‡=`B3772` BUILDS THE KERNELS `-MARCH=NATIVE` (SIMD ISA PINNED; THE ARM64/GCC-15 BUILDS, NOT SHOWN, EQUAL ARM64/CLANG; X86 DEFAULT 170, CONTRACTION OFF 141); N/T=NOT TESTED; $\neq$=TENSOR-DATA HASH DIFFERS IN ALL FOUR REBUILDS (THREE DISTINCT HONEST OUTPUTS). NO MODEL CARD RECORDS EITHER COORDINATE.

target (tensors)	quant	arm64 default card / +rec	arm64 contr. off card / +rec	x86 (either) card / +rec
Qwen3.5-0.8B (335)	`Q4_K_M`	140 / 193	260 / **335***	260 / **335***
Qwen3.5-2B (335)	`Q4_K_M`	140 / 193	260 / **335***	260 / **335***
Qwen3.5-4B (441)	`Q4_K_M`	184 / 252	341 / **441***	341 / **441***
Qwen3.5-0.8B (335)	`Q8_0`	298 / 334†	298 / 334†	299 / **335***
Qwen3.5-2B (335)	`Q8_0`	298 / 334†	298 / 334†	299 / **335***
Qwen3.5-4B (441)	`Q8_0`	393 / **441***	393 / **441***	393 / **441***
Qwen2.5-7B (339)	`Q8_0`	**339*** / —	**339*** / —	**339*** / —
Qwen2.5-7B (339)	`Q4_K_M`	141 / —‡	141 / —‡	170 / —‡
granite-4.2-3b (363)	`Q4_K_M`	n/t	n/t	263 / **363***
granite-4.2-3b (363)	`Q8_0`	n/t	n/t	**363*** / —
Qwen2.5-1.5B pilot	`Q4_K_M`	$\neq$ / —‡	$\neq$ / —‡	$\neq$ / —‡

g) The calibration input is a further unverifiable hop: Re-derivation above used the publisher's *own* imatrix, taken as given. Can a verifier instead recompute it? We regenerate the 0.8B imatrix from the fp16 and the calibration corpus its card links (identical `sha256`) at the stated release. The structure re-derives exactly—the entry set and all 186 entries' token *counts* match—but the accumulated importance values do not: $0/186$ are bit-identical, differing by a median relative 5.5×10^{-5} from the published imatrix on both an arm64 and an x86 CPU (which themselves differ by 2.2×10^{-5}), while `-ffp-contract=off` leaves the arm64 imatrix unchanged. The sensitivity is thus to the architecture rather than to contrac-

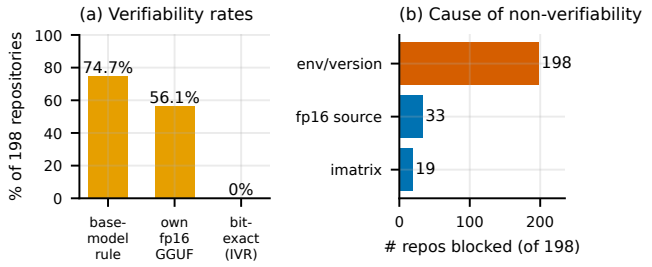

Fig. 1. (a) Source-reconstructible rates under the two rules (both ignore E) and the Independent Verifiability Rate under the recorded-inputs protocol; (b) the causes of non-verifiability. Both over the 198 GGUF-bearing repositories of the top 200, from metadata and model cards.

tion, and since no CPU build we tested matches the published imatrix, it was presumably produced on an accumulation path we did not test. The difference is not inert: re-quantizing with our recomputed imatrix instead of the published one—at the recipe and `-ffp-contract=off` environment that otherwise reproduce the file bit-for-bit—changes $141/335$ tensors. A verifier must therefore *obtain* the exact imatrix and bind it by hash, as our protocol does (§VII); recomputing C from the same disclosed corpus yields a different C, and hence a different Q. Calibration-input generation is thus a third hop in the chain, alongside the fp16 conversion and the quantization itself, and the second we find to be environment-sensitive.

V. M2: Locating the Ambiguity

If $0/198$ artifacts record E, the natural rejoinder is that E may not matter—that running the same recipe on the same weights yields the same bytes regardless of environment, as a deterministic pure function would. We test this directly. We build `llama.cpp` at the pinned release build `b10448` on two platforms—arm64/clang (Apple M4) and x86_64/gcc (Linux), the two (architecture, compiler) pairs tested throughout—each in a *default* and a `-ffp-contract=off` variant (PR #25353). On each we quantize one fixed fp16 GGUF (the f16 published by `bartowski/Qwen2.5-1.5B-Instruct-GGUF`, the pilot repository of §IV; `sha256` identical on both machines; no imatrix, $C{=}\varnothing$) into four types: the scale-search k/i-quants `Q4_K_M`, `Q5_K_M`, and `IQ4_XS`, plus `Q8_0` as a control that carries no scale search. (Table IV lists every experimental setup.) Same-binary, same-machine quantization is bit-deterministic ($16/16$ configurations—2 platforms $\times$ 2 builds $\times$ 4 types, each re-run 10 times with a single `sha256`), as expected; that determinism is the baseline, not the finding. The cross-platform divergence below, its floating-point-contraction cause, and the flag that removes it were reported alongside ggufpacker and PR #25353 [9], [10]; we reproduce them independently, as the empirical witness for Observation 1, and add a weight-space localization, a size trend, and a paired quality check.

a) Quantization is not a pure function of (W, θ): With $\bar{X}$ held fixed, the two architectures' *default* builds produce byte-differing outputs for 3 of the 4 quant types; only `Q8_0`, which carries no k-quant scale search, matches across architectures ($1/4$). As PR #25353 reports, the divergence traces to compiler-controlled floating-point contraction—fusing $a \cdot b + c$ into a single fused multiply-add—inside the k-quant scale-search loop of `ggml-quants.c`: the fused and unfused forms round differently near ties, select different block scales, and thereby write different nibbles; our byte localization below is consistent with this. Compiling with `-ffp-contract=off` collapses all four types to bit-identical across both tested (architecture, compiler) pairs ($4/4$ types), i.e. $B_{\mathcal{E}'}(\bar{X}){=}0$ for $\mathcal{E}'$ the two tested pairs with contraction disabled. The same pattern holds at an older release and with a real calibration input ($C{\neq}\varnothing$): in the `b3772` pilot re-derivation of §IV (1.5B), the two `-ffp-contract=off` outputs are tensor-identical across platforms with and without the imatrix, while the default outputs differ. The environment therefore silently changes the *weights*, and a single compiler flag removes the observed cross-environment divergence. The flag does not, however, *eliminate* E: it is itself a recorded E coordinate, and the quantizer version still varies, so it makes recording E cheap—a version plus one build flag—

TABLE IV
Experimental setups. Models are Qwen2.5-Instruct unless stated; builds are CPU-only `llama.cpp` in a default and a `-ffp-contract=off` variant on arm64/clang (Apple M4) and x86_64/gcc (Linux). At `b10448` the GGML quant kernels compile without `-march=native`, so the x86 default build's quant path is baseline x86-64 (no FMA, hence uncontracted) while arm64 (NEON, FMA available) contracts by clang's default; this is why `-ffp-contract=off` is the setting that makes the two architectures agree for the scale-search types (the `Q8_0` all-zero-block residual at `b9222`, §IV, is a separate architecture dependence). A `_M` preset stores its k-quant tensors in the named format, so §VI writes `Q4_K` for `Q4_K_M`.

Experiment	Release	Inputs and conditions
Cross-architecture (§V)	`b10448`	1.5B publisher f16; `Q4_K_M`, `Q5_K_M`, `IQ4_XS`, `Q8_0`; no imatrix; 10 repeats
Size trend (§V)	`b10448`	1.5B, 7B, 14B; `Q4_K_M`; arm64 default vs. contraction off
Quality (§V)	`b10448`	1.5B; `Q4_K_M`; wikitext-2, 584 chunks
Pilot re-derivation (§IV)	`b3772`	1.5B publisher f16 and imatrix; `Q4_K_M`; both platforms and builds
Trial re-derivation (§IV)	`b3772`, `b9222`, `b10603`	7B, Qwen3.5-0.8B/2B/4B, granite-4.2-3b; publisher full-precision GGUF and imatrix; `Q4_K_M`, `Q8_0` (all 23 types for the 0.8B); stock preset vs. pinned recipe; x86_64 and arm64, default and contraction off
Imatrix regeneration (§IV)	`b9222`	Qwen3.5-0.8B; card-linked corpus; arm64 (both builds) and x86_64
Conversion (§IV)	`b3772`, `b10448`	1.5B provider safetensors to f16; x86_64; 2 runs each
Security (§VI)	`b10448`, `b3772`	1.5B (0.5B for one overlap); `Q4_K`, `Q5_K`, `Q6_K`, `IQ4_XS`; six honest pairs for `Q4_K`; 5 seeds
Adaptive tampering (§VI)	`b10448`	1.5B; `Q4_K` scale $\times(1{+}\epsilon)$ sweep with perplexity; adaptive placement; targeted `Q6_K` embedding edit, two probes

rather than unnecessary (§VII). The switch also has negligible quality cost in the configuration we evaluated (Qwen2.5-1.5B-Instruct, `Q4_K_M`, wikitext-2 [18]): with each build quantizing the same f16, the `-ffp-contract=off` artifact scores *perplexity* (the standard next-token quality metric; lower is better) 10.750 versus 10.744 for the default build—$\Delta\text{PPL} = +0.006$ ($+0.06\%$; paired standard error 0.005 over the 584 evaluation chunks, so not distinguishable from zero)—though the two artifacts byte-differ, in line with PR #25353's report of effectively unchanged perplexity. We did not evaluate other models, types, or tasks.

b) The divergence lives in the weights, not in metadata: Byte-localizing the cross-architecture diff ($C{=}\varnothing$), we find the GGUF key–value/metadata region bit-identical; all divergence falls in the quantized weight tensors, concentrated in the k-quant per-block scale parameters (per-byte difference rate 1.2×10^{-3}, the highest of any region) and propagating into the packed nibbles (which hold 73% of the differing bytes by count but at a lower per-byte rate, 3.4×10^{-4}). This is precisely where the normalization half of the reproducible-builds recipe fails to transfer: beyond the local file paths recorded with an imatrix (which could be canonicalized), the non-determinism is in the numeric content of the weights themselves, so metadata normalization cannot reach it. That leaves the recipe's other two remedies: making E irrelevant (as the flag does) or recording it (§II).

c) The effect persists with scale: The same compiler-controlled divergence appears at 1.5B, 7B, and 14B parameters (Qwen2.5-Instruct f16 at each size), and across the three sizes we measured the fraction of divergent bytes grows with model size (Fig. 2b). The cross-architecture comparison is measured *directly* at 1.5B; at 7B and 14B we report a single-machine proxy: arm64 default vs. arm64 `-ffp-contract=off`. The proxy is exact at 1.5B: at `b10448` the x86_64 default output is byte-identical to every `-ffp-contract=off` output, so the proxy compares the same two byte streams as the cross-architecture pair and the two diffs coincide bit-for-bit.

Observation 1 (Necessity of E, under the studied model)**.** *For the `llama.cpp` k-quant family $\{\mathcal{T}(\bar{X}; E) : E \in \mathcal{E}\}$, there exists an instance $\bar{X}$ with $|\mathcal{A}(\bar{X})| \geq 2$, hence $B(\bar{X}) > 0$; so a specification scheme that pins $\bar{X}$ but leaves E free is not complete, and any complete specification must constrain E, i.e. $E \in X^*$.*

Proof sketch. Exhibit one instance ($\theta{=}$`Q4_K_M`) and two environments (x86_64/gcc vs arm64/clang, defaults) whose honest outputs byte-differ (§V). Appendix A; the experiments separately identify $\bar{X} \cup \{E_{\text{fpcontract}}\}$ as a *sufficient* completion for the tested environments. We claim empirical necessity *for this model*, not that every model requires E, and we do not claim to have characterized X^* in full.

Scope (where CUDA enters). `llama.cpp` quantization runs on CPU, so a CUDA-enabled build executes the same CPU quantization code (we did not test CUDA builds separately). GPU matters for (i) imatrix generation C, which §IV already finds architecture-sensitive on CPU and which GPU reduction order may perturb further (GPU builds untested here), and (ii) GPU-native pipelines (GPTQ/AWQ), which may lack $B{=}0$ and fall to attestation.

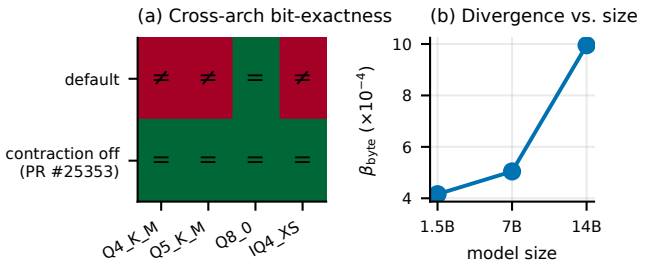

Fig. 2. (a) Cross-architecture bit-exactness at 1.5B: default builds byte-differ for 3 of 4 types; `-ffp-contract=off` restores bit-identity (4/4). (b) The fraction of divergent bytes β_{byte} (arm64 default vs `-ffp-contract=off`, the single-machine proxy of §V; `Q4_K_M`) grows with model size.

VI. M3: Security Characterization

This section is a security *characterization*, not a proposed defense. The question it answers is whether the ambiguity of §V is dangerous: when $B_{\mathcal{E}'}{>}0$, an honest cross-environment rebuild already yields a nonzero diff, so does benign non-determinism *look like* tampering and leave a verifier unable to tell them apart? We measure the two perturbation distributions in dequantized weight space. For each weight tensor, Δw denotes the per-weight difference between the two dequantized artifacts compared, and σ the standard deviation of that tensor's dequantized weights; all perturbation magnitudes below are reported as the normalized $|\Delta w|/\sigma$.

a) Two signatures: Benign non-determinism—the natural-variance distribution $\mathcal{R}_{\text{nat}}$—is measured here as the divergence of the arm64 default rebuild from a *reference* output (the `-ffp-contract=off` build, which both tested platforms reproduce bit-for-bit, §V; a designated measurement reference, not a canonicity claim), i.e. floating-point-contraction variance at a fixed release (`b10448`) without an imatrix. It touches only a small fraction of weights (0.22% for the `Q4_K_M` artifact, 0.056% for `Q5_K_M`; Qwen2.5-1.5B-Instruct) and moves each by a *tiny* amount: median $|\Delta w|/\sigma = 0.014$ (99th percentile 0.26) and 0.0017 respectively, because the scale drift nudges the affected weights by a sub-step. A cheating quantizer that tampers by flipping nibbles ($Q \neq \mathcal{T}$) moves each touched weight by one quantization step of its block—median $|\Delta w|/\sigma \approx 0.27$ for uniformly placed Q4_K flips, roughly $20\times$ larger (finer formats have smaller steps: 0.13 for Q5_K, 0.06 for Q6_K). The per-weight change is thus bounded below by the local step size (§II), not by how few weights are touched: it cannot be shrunk by making the attack sparser. It can be shrunk by *placement*: in blocks with small scales one step is small (0.43% of the Q4_K weights have a one-step move below the threshold used below), so an adaptive attacker confined to such blocks could evade it; the floors below are for uniformly placed flips, and adaptive placement is measured at the end

of this section. We validated the per-flip step size against the attack's arithmetic: a synthetic ±1-step flip gives median 0.268, matching a direct diagnostic on real weights (2,000 nibble flips applied in place to the 0.5B model: median 0.277).

b) Separation and detection floor: The two magnitude distributions barely overlap: the overlap coefficient (histogram intersection, $\sum_b \min(p_b^{\text{nat}}, p_b^{\text{tamper}})$ over a fixed $|\Delta w|/\sigma$ binning, which compares the magnitudes of changed weights, not their number) is 0.036 for one-step nibble flips on Q4_K at 0.5B (Qwen2.5-0.5B-Instruct), and 0.076 (Q4_K) and 0.053 (Q5_K) at 1.5B. The operative quantity is the *detection floor*: the smallest tampering budget still distinguishable from benign non-determinism. Because the separation is one of magnitude, a simple statistic realizes it—a per-tensor tail fraction, the fraction of weights with $|\Delta w|/\sigma$ above τ=0.1. We build each tampered artifact the way a cheating quantizer on another platform would produce it—its honest rebuild plus uniformly placed one-step flips—and score it against the verifier's reference (five seeds; budgets from 0.002% of weights). Against the arm64 contraction pair at a known release, the per-tensor floor (the smallest budget with AUC ≥ 0.99 in every seed, over 165–197 tensors per type) is 0.02% of weights for Q4_K, 0.005% for Q5_K, 0.05% for Q6_K (whose single steps mostly fall below τ), and 0.005% for IQ4_XS. Each floor lies above the natural boundary-crossing noise, the median per-tensor fraction of weights whose benign drift itself exceeds τ (0.018% for Q4_K, at most 0.002% for the others; distinct from the 0.22% of weights touched at *any* magnitude) (Fig. 3b). One budget step above each floor, TPR at FPR 1% is 1.0 in every seed. We report this as evidence that the distributions are separated, not as a defense we propose; a statistic exploiting an attack's spatial clustering may lower the floor (future work).

c) The floor depends on the environment pair: Benign differences vary by an order of magnitude across the Q4_K environment pairs we have (Fig. 3c): 0.018% of weights exceed τ between the arm64 builds, 0.034% with an imatrix, and 0.13–0.19% between the native x86 build and the reference; the publisher's 1.5B artifact (the pilot of §IV) against our `b3772` rebuild sits at 0.13%, like the x86 pair. The per-tensor floor rises accordingly, from 0.02% to 0.1%. This separation is robust to the tail threshold: repeating the analysis at $\tau \in \{0.05, 0.2\}$ preserves the pair ordering and flags no honest artifact, with the model-level threshold scaling as expected (0.41%, 0.19%, 0.08% at τ=0.05, 0.1, 0.2) and the max threshold, which does not involve τ, unchanged at 2.36. A verifier who does not know which environment produced an artifact must allow for all of the pairs it may face: calibrating a model-level rule on the five known-release pairs (flag a model whose pooled tail exceeds 0.19%, the largest benign value among them) raises no alarm on those pairs by construction, none on the held-out published artifact, and flags every tampered model from 0.2% of weights up, in every pair and seed. Read the other way, this is a hiding capacity that grows with the range of environments a verifier must allow: in the 1.1B Q4_K weights of the 1.5B model, up to about 2×10^6 uniformly placed one-step edits (just under 0.2%, for the five-pair calibration and an attacker on a low-noise pair) stay within what the statistic must attribute to benign environment variation, and more as that range widens. For a verifier who knows the environment pair but cannot replicate the producer's build, the capacity falls to about 2×10^5 (one who can replicate it simply compares hashes). Either way it is a quantitative case for B=0, under which a single edit changes the hash.

d) Sparse large edits: The tail statistic counts edits, so a handful of large ones escape it. A max statistic—the largest $|\Delta w|/\sigma$ in the model—does not: across the Q4_K pairs, honest artifacts reach at most 2.36, while moving a single weight's code to its farthest value already exceeds that in every seed and pair (2.40–2.52), and five such edits reach at least 2.57. The two statistics are complementary—many small edits raise the tail count, a few large edits raise the maximum—so an attacker who stays below both must make few, small edits, which is the capacity bounded above.

e) Scope: These are uniform, untargeted code edits on one model family. We additionally evaluate three adaptive variants. The first perturbs per-block *scales* (§II), which moves every weight in a block by sub-step amounts. When we multiply every Q4_K super-scale by $1+\epsilon$ and sweep ϵ, the pooled tail catches every perturbation in the sweep that is large enough to harm the model—at ϵ=0.02 perplexity diverges ($> 10^6$) and the pooled tail is 1.3%, well above the 0.19% threshold—while ϵ=0.005 evades all three statistics (per-tensor tail, pooled tail, max) at a perplexity cost of $+0.29\%$, and ϵ=0.01 still evades the pooled and max statistics (the per-tensor statistic is borderline there) at $+0.98\%$—a few times to an order of magnitude above the benign environment drift ($+0.06\%$), but far below a damaging level (the sweep scores each perturbed artifact against the unperturbed one). In this sweep, the blind spot to a uniform scale perturbation is bounded and behaviorally minor. The second variant is adaptive *placement*: an adversary who flips the codes whose one-step $|\Delta w|/\sigma$ is smallest hides up to the reservoir of such weights—0.43% of the Q4_K weights here ($\approx$4.7M)—with the pooled tail near zero and the max statistic below 0.12, evading all three statistics, whereas the same number of *uniformly* placed flips is caught (max 2.4–7.1 $>$ 2.36 across the budgets tested). This is a genuine blind spot, but a bounded, low-leverage one: the hidden edits are by construction the lowest-magnitude ones (their total weight change is about 4–$8\times$ smaller than uniform placement). The third, *targeted* case (e.g. rounding-guided injection [19]) is different in kind, and we treat it next. When B=0, all of these remain soundly detectable by exact re-derivation regardless (§VII).

f) A targeted attack defeats the statistic: The bounded blind spots above are for untargeted edits. A *targeted* tamper is different in kind. Qwen2.5-1.5B ties its input and output embeddings, so a token's output logit is $\langle h, E_t \rangle$ for the final hidden state h; an adversary can raise a chosen token's logit by one-step edits to its embedding row, and—because that row is `Q6_K`, whose one-step move is below τ for 95.5%

of elements—can restrict itself to sub-τ edits. Doing so flips the model's greedy next token to the chosen one while *every* edit stays below τ (max $|\Delta w|/\sigma \leq 0.10$, no edit above τ, pooled contribution $\approx 10^{-6}$), evading all three statistics; we confirmed the flip on two probes by a full-precision forward pass with the tampered, dequantized embedding swapped in (e.g. "the opposite of hot is" $\rightarrow$ *hot*, and a factual completion redirected to a rank-10 alternative). One embedding row's sub-τ budget covers a $\sim$4-logit margin here—enough to promote a plausible alternative to the top; a far target needs above-τ edits or several rows, and on a third probe ("two plus two equals") the predicted margin was reached with sub-τ edits but the forward pass did not flip, so one row's budget is not always sufficient. The statistic therefore characterizes the benign and untargeted regimes but is *not* a guarantee against a targeted cheating quantizer. This is why the protocol rests on $B{=}0$ exact re-derivation rather than statistical detection: when $B{=}0$, any edit—targeted or not, sub-τ or not—is a hash mismatch (§VII).

g) Threat boundary: The characterization above concerns a cheating quantizer ($Q \neq \mathcal{T}$). An adversarial-fp16 attack such as Mind the Gap [11] differs in kind: the publisher honestly quantizes a maliciously prepared fp16 ($Q = \mathcal{T}$), so the signed W is itself the attack and re-derivation reproduces the artifact exactly—it lies outside re-derivation by definition (A1), not by measurement, and neither our re-derivation analysis nor the statistic above addresses it.

VII. Verification Protocol

The measurements above compose into a verification recommendation whose parts depend on one another in a specific order. The precondition is $B{=}0$ over the environments rebuilders use ($B_{\mathcal{E}'}$, §III): when the honest output is unique, an honest independent rebuilder that recomputes Q and compares hashes can soundly detect any deviation $Q \neq \mathcal{T}(\bar{X}; E)$—assuming the committed inputs and hash are sound (A2, A4)—so a cheating quantizer cannot hide an edit to the fp16$\rightarrow Q$ step (R1, Appendix A). Inputs it supplies itself (W, C, M) are bound by the manifest, not vetted (§II). $B{=}0$ is sufficient rather than necessary: if the plausible environments form a small, known set $\mathcal{E}'$, a verifier can instead accept Q when it lies in $\{\mathcal{T}(\bar{X}; E) : E \in \mathcal{E}'\}$. Without a recorded E that set is not known: our `b3772` pilot (§IV) enumerated three distinct honest outputs, including a native FMA-capable x86 build, and the published artifact was none of them. Recording E makes membership checkable, and $B{=}0$ over the rebuilders' environments reduces it to a single hash comparison. When $B{>}0$, a nonzero diff no longer implies tampering (§VI); verification can no longer rely on exact hash equality, and for the evaluated cheating-quantizer threat, detection is instead characterized by a detection floor that grows with the range of environments the verifier must allow (0.02–0.2% of Q4_K weights, §VI). Because $B{=}0$ over the tested platforms is attainable by one compiler flag (PR #25353) at negligible measured quality cost (§V), yet is not the `llama.cpp` default (the PR remains open as of September 2026), the first recommendation is simply to make deterministic quantization the default. This does not remove E from the specification: the flag is itself an E coordinate, and $B{=}0$ is an empirical property of the tested (architecture, compiler) pairs at the releases and types we tested (`b10448`; `b3772` and `b9222` for `Q4_K_M`) rather than a universal one: at `b9222` a `Q8_0` tensor with all-zero blocks still stores architecture-dependent codes (§IV), so the record must include the architecture or the kernel must canonicalize zero blocks. The manifest below therefore still records E—enabling the flag only makes that record cheap (the quantizer version plus one build flag).

Given $B{=}0$, the architecture is the reproducible-builds pattern adapted to quantization, differing from today's ecosystem in *what is signed*. The transforming party—the quantizer, not only the original model signer—signs a manifest committing to the inputs it used, $(H(W), \theta, C, E, M)$, so that the claim "$Q = \mathcal{T}(\bar{X}; E)$" becomes checkable rather than asserted. Independent rebuilders recompute Q from the manifest and publish signed match/mismatch results to an append-only transparency log (publicly readable and append-only, so a mismatch report cannot be quietly removed); end users verify the published results without performing the rebuild themselves. This inverts the current trust relation, in which a signature over Q certifies its origin but not its faithfulness to W (§II). The primitives here are standard—a signed manifest as in in-toto's link attestations [20], an append-only transparency log as in Sigstore's Rekor [21], and cross-machine bit-exact re-derivation as ggufpacker already performs for the quants it packs [9]. Our contribution is not this machinery but the measured specification of *what it must bind* for a GGUF quantization to verify: the build's FP-contraction coordinate (§V), the per-tensor recipe (§IV), and a hash of the exact imatrix, which §IV shows an independent party could not recompute on the CPUs we tested. A publisher-side packager pins these coordinates implicitly for the quants it packs, but none of the signing or attestation specifications we examine (§II) requires them.

A tempting shortcut is to verify only a random sample of the artifact rather than re-derive all of it: the manifest would additionally commit to Q via a Merkle root over its N superblocks, letting a verifier *open*—request and re-derive—individual units. Its cost, however, grows precisely as the adversary that matters—sparse tampering—becomes sparser. The bound below is the standard spot-checking argument of provable data possession [22], which we apply to partial re-derivation.

Proposition 1 (Sampling bound; standard, cf. [22])**.** *A partial verifier re-deriving a uniform k-subset of N units catches an m-unit tampering with $P_{\text{det}} = 1 - \binom{N-m}{k}/\binom{N}{k}$, satisfying $1 - e^{-km/N} \leq P_{\text{det}} \leq km/N$. Attaining $P_{\text{det}} \geq 1 - \delta$ needs $k = \Theta(N/m)$.*

Proof sketch. Union bound on $\mathbb{E}|U \cap S| = km/N$ for the sampled k-subset U and tampered set S (necessity) and $\binom{N-m}{k}/\binom{N}{k} \leq e^{-km/N}$ (sufficiency); Appendix A. For sparse tampering the required budget grows as N/m, approaching full

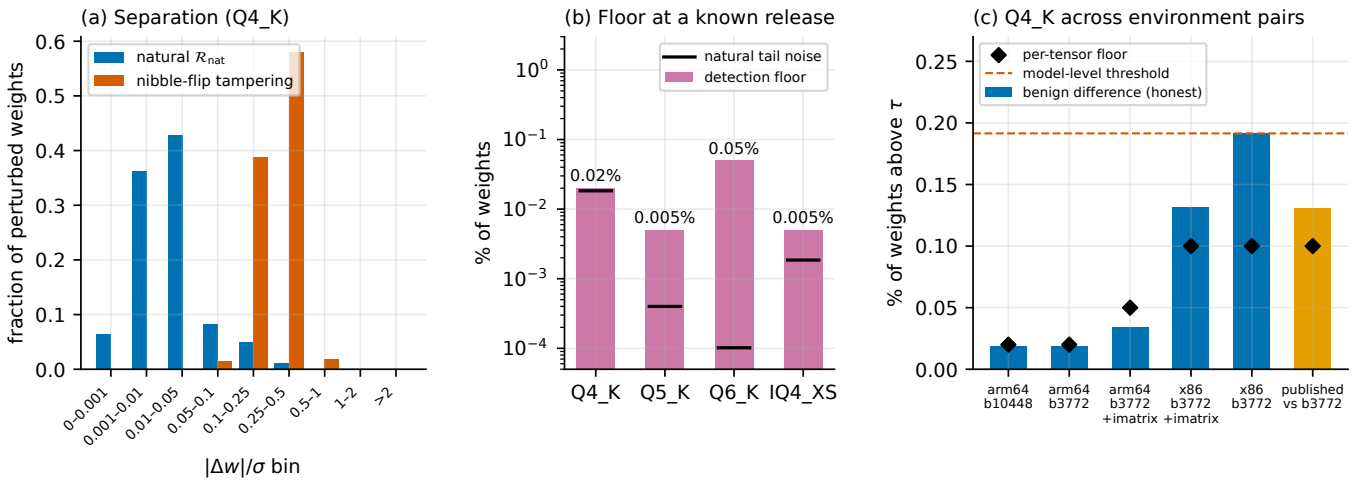

Fig. 3. Security characterization (Qwen2.5-1.5B-Instruct): (a) natural vs. nibble-flip perturbation distributions (Q4_K); (b) per-tensor detection floor at a known release (arm64 contraction pair; tampered = honest rebuild plus uniformly placed one-step flips; AUC ≥ 0.99 in every seed) and the natural tail noise it must exceed; (c) Q4_K across environment pairs: benign difference (fraction of weights above τ), each pair's per-tensor floor, and the model-level threshold calibrated on the known-release pairs.

re-derivation as $m \to 1$, so spot-checking is weakest where detection matters most (and each opened unit also needs its fp16 inputs authenticated against $H(W)$, which a flat hash supports only by downloading W); we favor full re-derivation when reproducible, with attestation as a *residual* mechanism only where re-derivation is unavailable.

VIII. Discussion & Limitations

Relative to ggufpacker and PR #25353, what is new is the ecosystem measurement and its decomposition, the localization of the failure to the quantization step (the fp16 re-derives exactly, the quantized weights do not), the two card-absent coordinates and the imatrix we could not recompute, which a manifest must therefore bind, the vocabulary that makes the verifier's requirement precise, and the security characterization of the $B{>}0$ regime. **Limitations:** models (Qwen 0.5B–14B, one Granite 3B), types (Q4_K, Q5_K, Q6_K, IQ4_XS, plus Q8_0 as a determinism control; all 23 published types of one repository for re-derivation only), pipeline (`llama.cpp` CPU quantization). Out of scope: GPU imatrix generation C and GPU-native pipelines (GPTQ/AWQ/bitsandbytes), which may require attestation rather than re-derivation; and adversarial-fp16 attacks, which no transformation-level check—re-derivation or attestation—detects, since the transformation is honest. The floors are measured for uniformly placed one-step flips (and farthest-code edits for the max statistic) against six environment pairs of one model family, plus uniform scale-perturbation, adaptive-placement, and targeted-embedding sweeps (§VI). The targeted embedding attack defeats the statistic, which is why the protocol rests on $B{=}0$ exact re-derivation rather than detection. We do not evaluate adversarial-fp16 attacks; a preliminary run of the Mind-the-Gap code on a 0.5B model did not yield a working attack and is reported in the artifact only. The 12-card LLM audit is a sample, complemented by a pattern scan of all 198 cards (§IV). **Recommendations:** `llama.cpp`/GGUF should record the quantizer version and build flags and merge PR #25353; IETF/ML-BOM should bind C and E.

IX. Related Work

Reproducible builds. The paradigm [1], [2], its tooling [12], [13], and automated localization of non-reproducibility [23] establish an independently verifiable source-to-binary correspondence, reducing the trust placed in the build process. We transfer this lens to model quantization and find that metadata normalization cannot reach its non-determinism; the environment must then be made irrelevant or recorded [14], and neither is current practice (§IV, §V). **Model signing & attestation.** Sigstore Model Signing [3], [4] authenticates the identity of the released files; provenance and lifecycle efforts—the IETF lifecycle-attestation draft [6], the CycloneDX ML-BOM transparency inventory [7], and attestation of LLM pipelines [15]—describe more of the pipeline, and some record deployment or toolchain context. What none of the specifications we examine *requires* is the specific calibration artifact C, or execution-environment information (compiler, architecture, FP-contraction setting) in a form a verifier can re-create, both of which our bit-exact GGUF re-derivation protocol consumes (§II). Our manifest is an in-toto-style provenance statement [20] published to a transparency log as in Sigstore [21]; SLSA provenance [24] has generic slots that could carry C (resolved dependencies) and E (build parameters), so what quantization needs is a profile that makes them mandatory and names their contents. Empirical studies of the Hugging Face ecosystem report missing provenance and reproducibility attributes as a general reuse challenge [25], and model-card

completeness is uneven [17]; our census quantifies one such attribute, the quantization environment, for the deployed GGUF slice. A concurrent registry study functionally tests 327 GGUF artifacts and finds silently defective official builds [26]; it checks behavior where we check provenance by re-derivation, and the two are complementary. Statistical certification of a compressed model's quality [27] is likewise orthogonal to provenance. Attestable Builds [28] obtain verifiable binaries from TEEs instead of rebuilds, the residual route we leave to attestation. **Quantization-time attacks.** Mind the Gap [11], its predecessor on LLM quantization [29], and, more generally, Qu-ANTI-zation and quantization backdoors against commercial toolkits [30], [31] demonstrate *quantization-conditioned* attacks: an adversarially prepared full-precision model behaves maliciously only after quantization (targeted misclassification or backdoor, across quantization schemes). Because the quantization step itself is faithful ($Q = \mathcal{T}$), these fall outside our cheating-quantizer threat model—re-derivation reproduces them rather than flagging them—but they define the threat class that §VI places outside re-derivation. Closer to our cheating quantizer, rounding-guided backdoor injection [19] flips the rounding direction of selected weights during quantization, and bit-flip attacks show that a few targeted weight changes can suffice [32]; both are the natural attacks to place against the statistics of §VI, whose targeted-embedding evaluation is a simple exact, gradient-free relative of the former. Defenses that re-round weights, such as EFRAP [33] and QuantGuard [34], would themselves depart from a canonical bit-exact $\mathcal{T}$. **Non-weight (metadata) backdoors.** A parallel surface is the non-weight component M: training-free backdoors carried in the chat template, with the weights left untouched [35], [36]. These motivate treating non-weight components such as chat templates as part of the signed manifest (§VII), though detecting them is orthogonal to re-derivation. **Verifying ML computation.** zkML [37] and locality-sensitive commitments over activations [38] verify *inference* computations, and deterministic-inference work removes floating-point non-determinism from the forward pass [39] or replays it bit-exactly as an audit signature [40]. All target the inference that consumes a deployed model, not the *transformation* $\mathcal{T}$ that produces it; our focus is the latter, verified by re-derivation.

X. Conclusion

The ML supply chain authenticates identity but deploys transformations that are insufficiently specified to support independent bit-exact verification; in our popularity-sampled slice the recorded-inputs IVR is $0/198$, and re-derivation by environment search succeeded, in our trial, for recent releases but not for an older one. For the studied `llama.cpp` quantization pipeline, the environment gap is closable for newly produced artifacts on the tested platforms—by enabling deterministic quantization, at negligible measured quality cost, and recording the release and build—while the remaining source gaps require publishers to release their fp16 and imatrix, together with the per-tensor recipe, since an independent party could not recompute the imatrix in our attempt; adoption carries engineering cost. Until it closes, benign environment variation leaves room to hide: up to about 0.2% of uniformly placed one-step weight edits (some 2×10^6 at 1.5B, and more as the admissible environment range widens) stay within what the evaluated statistic must attribute to it, an adaptively placed adversary hides a further low-magnitude reservoir, and a targeted edit evades the statistic outright. We provide a re-runnable audit and tools to track the IVR.

Ethical Considerations

This is a measurement and characterization study; it introduces no new attack class. Our audit reads only public information from public Hugging Face repositories (file inventories, model cards, and GGUF headers fetched by range requests); we collect no personal data and report aggregate rates rather than judgements of specific publishers—the repositories we name (§IV) are best cases whose publisher discloses more than most. The cheating-quantizer analysis and detector are defensive—they separate benign non-determinism from tampering to aid verification. We ran one previously published attack procedure (Mind the Gap) with its authors' public code on a small model, which did not yield a working backdoor in our run, and we redistribute no attacked model; the synthetic nibble-flip constructions and the targeted-embedding check (which flips a next-token prediction on a neutral probe) are diagnostic detector evaluations, not deployable backdoors. Our central recommendation—recording the execution environment and enabling deterministic quantization, as an already-proposed upstream change (PR #25353) does—is a defensive improvement to the supply chain.

Open Science

All artifacts needed to evaluate our claims are available at https://github.com/Rlonglong/gguf-verifiability-artifact. They comprise the frozen 198-repository list with the scored census snapshot and the re-runnable scoring harness (`census.py`); the model-card audit verdicts and the classified pattern scan of all 198 cards; the GGUF header-probe, byte-region diff, tensor-data hash, and detector tools, with the detector evaluation over environment pairs; the cross-architecture, pilot and trial re-derivation (`b3772`, `b9222`, `b10603`), imatrix-regeneration, conversion, and perplexity drivers; the scale-perturbation, adaptive-placement, and targeted-embedding sweeps; and the raw per-figure data (CSV/JSON) with the scripts that render every figure and reported number. The inputs are public: Hugging Face model artifacts, pinned open-source `llama.cpp` builds (`b3772`, `b9222`, `b10448`, `b10603`), and, for the Mind-the-Gap workload, its authors' public code; we reference these by identifier rather than redistribute them. A Zenodo deposit will accompany the published version.

LLM usage considerations

LLMs were used for editorial purposes in this manuscript, and all outputs were inspected by the authors to ensure

accuracy and originality; the authors take full responsibility for every statement, number, and line of code in the paper and artifact. We also disclose two further uses. *Methodology:* the model-card audit of §IV used LLM agents (one Claude agent per card) instructed to refute our scorer's label. The IVR itself rests on deterministic metadata checks, which the agents could only confirm or contest; because the agent model is closed and its outputs may not be exactly reproducible, we complement the sample with a deterministic pattern scan of all 198 cards whose every hit we classified manually, and we release the per-card verdicts with their rationales so the conclusion can be checked without an LLM. *Engineering:* an LLM coding assistant helped write experiment and analysis scripts; every reported number comes from executed code and released raw data and was checked against that data by the authors, and every reference was verified against its source. *Footprint:* we train no models beyond the few hundred fine-tuning steps of the preliminary Mind-the-Gap run; our experiments are CPU quantization, a handful of perplexity evaluations, and a few GPU forward passes for the targeted-embedding check, on open models of at most 14B parameters, on one Apple M4 machine and one x86-64 workstation, and the census fetches only GGUF headers (8–16 MB per repository) instead of full model files.

REFERENCES

[1] C. Lamb and S. Zacchiroli, "Reproducible builds: Increasing the integrity of software supply chains," *IEEE Software*, vol. 39, no. 2, pp. 62–70, 2022. Preprint arXiv:2104.06020.

[2] Reproducible Builds project, "Reproducible builds — a set of software development practices that create an independently-verifiable path from source to binary code." https://reproducible-builds.org/, 2026. Debian per-suite statistics at https://tests.reproducible-builds.org/debian/reproducible.html; bookworm/amd64 reported ∼96.9% reproducible as of the access date.

[3] Sigstore project, "model-transparency: Supply chain security for ML." https://github.com/sigstore/model-transparency, 2026. Sigstore community / OpenSSF AI-ML working group project for cryptographic signing of ML models.

[4] Open Source Security Foundation (OpenSSF), "OpenSSF model signing (OMS) specification." https://github.com/ossf/model-signing-spec, 2026. PKI-agnostic model-signing standard; supports bare keys, certificate chains, and keyless Sigstore signing.

[5] M. Sablotny, D. Major, L. Seletos, R. Harang, and N. Hudait, "Bringing verifiable trust to AI models: Model signing in NGC." NVIDIA Technical Blog, https://developer.nvidia.com/blog/bringing-verifiable-trust-to-ai-models-model-signing-in-ngc/, July 2025. All NVIDIA-published NGC models are signed with the OpenSSF Model Signing (OMS) specification.

[6] R. Sharif, "Cryptographic attestation for AI model lifecycle: From training data to inference output," Internet-Draft draft-sharif-ai-model-lifecycle-attestation-01, Internet Engineering Task Force (IETF), Aug. 2026. Work in progress; individual submission, no IETF stream. Version 01 (26 August 2026); version 00 dated March 2026. https://datatracker.ietf.org/doc/draft-sharif-ai-model-lifecycle-attestation/.

[7] OWASP CycloneDX, "Machine learning bill of materials (AI/ML-BOM)." https://cyclonedx.org/capabilities/mlbom/, 2026. OWASP CycloneDX BOM standard, standardized as ECMA-424; provides model and dataset transparency.

[8] G. Gerganov and llama.cpp contributors, "llama.cpp: LLM inference in C/C++ (and the GGUF model format)." https://github.com/ggml-org/llama.cpp, 2026. GGUF format introduced Aug 2023; format spec under `docs/` and the `ggml` repository.

[9] ggufpacker project, "ggufpacker: bit-exact GGUF quantization recipes with cross-machine derivation attestations." https://github.com/theadamdanielsson/ggufpacker, 2026. Packs quant ladders as recipes and verifies that a GGUF quant is bit-exactly re-derivable across machines on public CI.

[10] theadamdanielsson, "ggml: make quantization bit-reproducible across compilers and architectures (-ffp-contract=off on ggml-quants.c)." https://github.com/ggml-org/llama.cpp/pull/25353, 2026. llama.cpp pull request #25353, opened July 2026; open as of September 2026. Evidence: github.com/theadamdanielsson/gguf-quant-determinism.

[11] K. Egashira, R. Staab, M. Vero, J. He, and M. Vechev, "Mind the gap: A practical attack on GGUF quantization," in *Proceedings of the 42nd International Conference on Machine Learning (ICML)*, vol. 267 of *Proceedings of Machine Learning Research*, pp. 15038–15065, PMLR, 2025. Also arXiv:2505.23786; code at https://github.com/eth-sri/llm-quantization-attack.

[12] Reproducible Builds project, "diffoscope: in-depth comparison of files, archives, and directories." https://diffoscope.org/, 2026.

[13] Reproducible Builds project, "reprotest: build software and check it for reproducibility." https://reproducible-builds.org/tools/, 2026. Builds source in varied environments and compares the resulting binaries.

[14] Reproducible Builds project, "Recording the build environment." https://reproducible-builds.org/docs/recording/, 2026. Accessed September 2026.

[15] Z. Tan, J. Singer, and C. Anagnostopoulos, "Attesting LLM pipelines: Enforcing verifiable training and release claims," in *Proceedings of the 2nd International Workshop on Large Language Model Supply Chain Analysis (LLMSC), co-located with FSE 2026*, 2026. To appear; preprint arXiv:2603.28988. Workshop co-located with FSE 2026, Montreal, Canada.

[16] ikawrakow, "k-quants." https://github.com/ggml-org/llama.cpp/pull/1684, 2023. llama.cpp pull request #1684, merged June 2023; introduces the Q2_K–Q6_K block formats.

[17] W. Liang, N. Rajani, X. Yang, E. Ozoani, E. Wu, Y. Chen, D. S. Smith, and J. Zou, "What's documented in AI? Systematic analysis of 32k AI model cards," *Nature Machine Intelligence*, vol. 6, no. 7, 2024. arXiv:2402.05160.

[18] S. Merity, C. Xiong, J. Bradbury, and R. Socher, "Pointer sentinel mixture models," in *International Conference on Learning Representations (ICLR)*, 2017. arXiv:1609.07843; introduces the WikiText-2 corpus.

[19] X. Chen, P. Zhang, J. Sun, W. Wang, and J. Wang, "Rounding-guided backdoor injection in deep learning model quantization," in *Network and Distributed System Security Symposium (NDSS)*, 2026. arXiv:2510.09647.

[20] S. Torres-Arias, H. Afzali, T. K. Kuppusamy, R. Curtmola, and J. Cappos, "in-toto: Providing farm-to-table guarantees for bits and bytes," in *USENIX Security Symposium*, 2019.

[21] Z. Newman, J. S. Meyers, and S. Torres-Arias, "Sigstore: Software signing for everybody," in *Proceedings of the ACM SIGSAC Conference on Computer and Communications Security (CCS)*, pp. 2353–2367, 2022.

[22] G. Ateniese, R. Burns, R. Curtmola, J. Herring, L. Kissner, Z. Peterson, and D. Song, "Provable data possession at untrusted stores," in *Proceedings of the 14th ACM Conference on Computer and Communications Security (CCS)*, pp. 598–609, 2007.

[23] Z. Ren, H. Jiang, J. Xuan, and Z. Yang, "Automated localization for unreproducible builds," in *Proceedings of the 40th International Conference on Software Engineering (ICSE)*, pp. 71–81, ACM, 2018. Preprint arXiv:1803.06766.

[24] OpenSSF, "SLSA: Supply-chain levels for software artifacts, version 1.0." https://slsa.dev/spec/v1.0/, 2023.

[25] W. Jiang, N. Synovic, M. Hyatt, T. R. Schorlemmer, R. Sethi, Y.-H. Lu, G. K. Thiruvathukal, and J. C. Davis, "An empirical study of pre-trained model reuse in the Hugging Face deep learning model registry," in *Proceedings of the 45th IEEE/ACM International Conference on Software Engineering (ICSE)*, 2023. arXiv:2303.02552.

[26] A. Patodiya, "Broken on arrival: Silently defective LLM artifacts in public model registries and how to catch them." arXiv:2609.05881, 2026.

[27] A. Singh, "Certifying compressed language models: An audit and a statistical toolkit." arXiv:2608.15046, 2026.

[28] D. Hugenroth, M. Lins, R. Mayrhofer, and A. R. Beresford, "Attestable builds: Compiling verifiable binaries on untrusted systems using trusted execution environments," in *Proceedings of the ACM SIGSAC Confer-*

ence on Computer and Communications Security (CCS), pp. 4514–4528, 2025.
[29] K. Egashira, M. Vero, R. Staab, J. He, and M. Vechev, "Exploiting LLM quantization," in *Advances in Neural Information Processing Systems 37 (NeurIPS 2024)*, 2024. arXiv:2405.18137.
[30] S. Hong, M.-A. Panaitescu-Liess, Y. Kaya, and T. Dumitras, "Qu-ANTI-zation: Exploiting quantization artifacts for achieving adversarial outcomes," in *Advances in Neural Information Processing Systems 34 (NeurIPS 2021)*, vol. 34, Curran Associates, Inc., 2021. Also arXiv:2110.13541; code at https://github.com/Secure-AI-Systems-Group/Qu-ANTI-zation.
[31] H. Ma, H. Qiu, Y. Gao, Z. Zhang, A. Abuadbba, M. Xue, A. Fu, J. Zhang, S. F. Al-Sarawi, and D. Abbott, "Quantization backdoors to deep learning commercial frameworks." arXiv:2108.09187, 2023. v3, April 2023.
[32] Z. Coalson, J. Woo, C. S. Lin, J. Qu, Y. Sun, S. Chen, L. Yang, G. Saileshwar, P. Nair, B. Fang, and S. Hong, "PrisonBreak: Jailbreaking large language models with at most twenty-five targeted bit-flips." arXiv:2412.07192, 2024.
[33] B. Li, Y. Cai, H. Li, F. Xue, Z. Li, and Y. Li, "Nearest is not dearest: Towards practical defense against quantization-conditioned backdoor attacks," in *IEEE/CVF Conference on Computer Vision and Pattern Recognition (CVPR)*, 2024. arXiv:2405.12725.
[34] A. Zheng, A. Du, Z. Deng, Y. Chen, S. Guo, and K. Zheng, "QuantGuard: Learnable rounding for repairing quantization-conditioned backdoors in LLMs." arXiv:2606.29239, 2026.
[35] A. Fogel, O. Hofman, E. Cohen, and R. Vainshtein, "Inference-time backdoors via chat templates: From LLM supply chains to agentic system compromise." arXiv preprint arXiv:2602.04653, 2026. Backdoor injected via the Jinja2 chat template (model metadata), leaving weights unmodified.
[36] Z. Wang, H. Li, R. Zhang, W. Jiang, and G. Xu, "BadTemplate: A training-free backdoor attack via chat template against large language models." arXiv preprint arXiv:2602.05401, 2026. Malicious instructions injected into the chat-template / system-prompt metadata; no model retraining required.
[37] B.-J. Chen, S. Waiwitlikhit, I. Stoica, and D. Kang, "ZKML: An optimizing system for ML inference in zero-knowledge proofs," in *Proceedings of the Nineteenth European Conference on Computer Systems (EuroSys '24)*, pp. 560–574, Association for Computing Machinery, 2024.
[38] J. M. Ong, M. D. Ferrante, A. Pazdera, R. Garner, S. Jaghouar, M. Basra, M. Ryabinin, and J. Hagemann, "TOPLOC: A locality sensitive hashing scheme for trustless verifiable inference." arXiv preprint arXiv:2501.16007, 2025. Detects model, precision, or prompt tampering via a compact hash of intermediate activations; non-zkML verifiable inference.
[39] H. He and Thinking Machines Lab, "Defeating nondeterminism in LLM inference." Thinking Machines Lab, Connectionism (blog), Sept. 2025. Batch-invariant kernels for bitwise-reproducible inference; adopted by SGLang. Published 10 Sep 2025.
[40] N. Cankaya, "Bit-exact AI inference verification without performance tradeoffs." arXiv:2606.00279, 2026.

APPENDIX A
PROOFS

Notation (recap). Split the non-environment inputs from the environment: $\bar{X} = (W, \theta, C, M)$, full input $X = (\bar{X}, E)$ with $E \in \mathcal{E}$; the implementation family is $\{\mathcal{T}(\bar{X}; E) : E \in \mathcal{E}\}$, the admissible-output set $\mathcal{A}(\bar{X}) = \{\mathcal{T}(\bar{X}; E) : E \in \mathcal{E}\}$, and $B(\bar{X}) = \sup_{Q_1, Q_2 \in \mathcal{A}(\bar{X})} d(Q_1, Q_2)$ with d the discrete metric on serialized artifacts (§III).

A. Proof of Observation 1 (necessity of E)

Proof. Fix a single instance $\bar{X}$: W = Qwen2.5-1.5B-Instruct fp16 (a fixed GGUF with $H(W)$ identical on both platforms), θ =`Q4_K_M`, C = $\varnothing$ (no imatrix), and M the model's metadata. Take two environments E_1 = (x86-64, gcc, default FP contraction) and E_2 = (arm64, clang, default FP contraction), with an identical pinned build configuration (CPU-only, static, Release) on both; thread counts differed (8 vs 6) and are separately observed not to affect the output (every configuration is bit-deterministic over 10 repeated runs, and the 8- and 6-thread `-ffp-contract=off` outputs are byte-identical). Building `llama.cpp` at the pinned release build `b10448` and quantizing on each platform (§V) yields $\mathcal{T}(\bar{X}; E_1) \neq \mathcal{T}(\bar{X}; E_2)$: the two outputs byte-differ ($H(\mathcal{T}(\bar{X}; E_1)) \neq H(\mathcal{T}(\bar{X}; E_2))$), with the divergence confined to the k-quant weight tensors (the metadata/KV region is byte-identical) and originating in the FMA-sensitive scale-search loop of `ggml-quants.c`. Hence $|\mathcal{A}(\bar{X})| \geq 2$ and $B(\bar{X}) > 0$: the specification that pins only $\bar{X}$ and leaves E free is incomplete, so any complete specification for this transformation family must additionally constrain E; thus $E \in X^*$. □

a) Remark (a sufficient completion; not a converse): Adding the single coordinate $E_{\text{fpcontract}}$ (compiling `ggml-quants.c` with `-ffp-contract=off`) makes the output bit-identical across the two environments above, i.e. across both tested (architecture, compiler) pairs (§V: $4/4$ bit-identical for the four types tested there, including the scale-search type `IQ4_XS`); thus $\bar{X} \cup \{E_{\text{fpcontract}}\}$ is a *sufficient* completion for the tested environments. This is separate from the observation itself, which establishes only that E is necessary. We do *not* claim (i) that $E_{\text{fpcontract}}$ suffices over *all* environments (untested compilers/GPUs may add coordinates), nor (ii) that *every* transformation model requires E—a family fixing a single canonical implementation would relocate the requirement into that implementation's specification rather than eliminate it. Characterizing X^* in full (GPU imatrix, other pipelines) is future work.

b) Consequence (specification gap): The deployed specifications we examine—Model Signing ($H(W)$ only), the IETF lifecycle-attestation draft, CycloneDX ML-BOM—do not require the execution-environment coordinates (compiler, target architecture, FP-contraction setting) that determine the output; the IETF draft binds deployment/TEE context and a quantization-tool hash, which identifies a binary but does not record the coordinates needed to re-create an equivalent one on another platform. They are therefore incomplete for independent re-derivation over the studied family: under their required fields, a verifier without the producer's binary and platform cannot determine which Q to expect. This underpins the execution-environment gap measured in §IV (the build coordinates of E absent from the GGUF metadata and the model cards of all 198 audited artifacts). We state this as *the necessity of E explains why the universal gap blocks re-derivation of scale-search artifacts*, not as *a* 0 IVR *is a formal consequence of missing E alone* (a 0 IVR can also arise from missing C, W, or θ).

B. Proof of Proposition 1 (sampling bound; standard)

Setup. Partition the artifact into N units (superblocks). The honest transformation fixes each unit's value. A tampering

adversary alters a set S, $|S| = m$, with $Q \neq \mathcal{T}(\bar{X}; E)$ exactly on S. A partial verifier re-derives a uniformly random subset $U \subseteq [N]$, $|U| = k$, and reports tampering iff $U \cap S \neq \varnothing$.

Proof. Exact form. $\Pr[U \cap S = \varnothing]$ is the probability a uniform k-subset avoids the fixed m-set S, $= \binom{N-m}{k}/\binom{N}{k}$; hence $P_{\text{det}} = 1 - \binom{N-m}{k}/\binom{N}{k}$.

Upper bound (necessity). With $Z_i = \mathbf{1}[i \in U \cap S]$ and $\mathbb{E}|U \cap S| = k \cdot (m/N)$, the union bound gives $P_{\text{det}} = \Pr[|U \cap S| \geq 1] \leq \mathbb{E}|U \cap S| = km/N$. Thus $P_{\text{det}} \geq 1 - \delta \Rightarrow k \geq (1-\delta)N/m$.

Lower bound (sufficiency). Writing the ratio as a telescoping product and using $(N-m-i)/(N-i) \leq 1 - m/N$ for each $0 \leq i < k$,

$$\frac{\binom{N-m}{k}}{\binom{N}{k}} = \prod_{i=0}^{k-1} \frac{N-m-i}{N-i} \leq \left(1 - \tfrac{m}{N}\right)^k \leq e^{-km/N},$$

so $P_{\text{det}} \geq 1 - e^{-km/N}$, and $e^{-km/N} \leq \delta \Leftrightarrow k \geq (N/m)\ln(1/\delta)$ suffices. Combining the two bounds, $k = \Theta(N/m)$. □

a) Corollary (spot-checking degrades with sparsity): For a 7B model, $N \approx 2.7 \times 10^7$ superblocks. Against sparse tampering $m = 10^2$, $\delta = 0.05$: the necessary budget is $k \geq 0.95\,N/m \approx 2.6 \times 10^5$, and $k = \ln(20)\,N/m \approx 8.1 \times 10^5$ suffices. Each opened unit needs a Merkle path of $\lceil \log_2 N \rceil \approx 25$ sibling hashes (∼32 B each), i.e. ∼800 B, for a proof of ≈ 0.2–0.65 GB as independent paths (a multiproof sharing upper-level nodes needs about $k \log_2(N/k)$ hashes, a few times fewer). The proposition establishes only that the spot-check budget scales as $\Theta(N/m)$; from this we draw two *engineering* conclusions (not theorem consequences): for sufficiently sparse tampering, spot-checking is impractical—its proof grows as N/m and approaches full re-derivation as $m \to 1$ (and authenticating the opened units' fp16 inputs against a flat $H(W)$ requires downloading W, ≈14 GB, anyway); and when full re-derivation is feasible ($B{=}0$) it avoids this budget entirely, with attestation a residual mechanism where re-derivation is unavailable.

C. Remark

R1. For a transformation instance with $B_{\mathcal{E}'}(\bar{X}){=}0$ over the rebuilders' environments $\mathcal{E}'$, the admissible output is unique; under A2 and A4, an honest rebuilder recomputing the transformation detects any $Q \neq \mathcal{T}(\bar{X}; E)$ except with negligible hash-collision probability.

APPENDIX B
ASSUMPTIONS AND SECURITY-CLAIM BOUNDARY

Our claims hold under the following assumptions. A1–A4 govern the primary contribution (re-derivation and the structural characterization); A5–A7 are needed *only* for the residual attestation fallback (§VII), which we treat as future work.

A1 (Boundary). The source signature sig_W is unforgeable and the signed source W is itself trustworthy. We do *not* address upstream poisoning: if W is malicious (an adversarial-fp16 model, Mind the Gap), an honest quantization of it is faithful, and neither re-derivation nor our detector flags it (§VI).

A2. The hash H is collision-resistant; underlies both the manifest commitments and the equality $H(Q') = H(Q)$.

A3 (modeling scope, not a free assumption). We model the studied transformation's inputs as $X = (\bar{X}, E)$ with $\bar{X} = (W, \theta, C, M)$—the candidate coordinates that may influence its output. This is the model we *test*, not something we take for granted: Observation 1 and §V establish that E must be constrained, §IV measures that deployed specifications omit it, and characterizing X^* in full is open.

A4. At least one rebuilder executes the specified transformation faithfully on the committed inputs. When $B_{\mathcal{E}'}{=}0$, one honest rebuilder that reproduces the canonical output already detects a deviation; using several independent rebuilders is an operational robustness measure, not part of the soundness argument.

A5–A7 (residual only). TEE hardware isolation is sound (A5); attestation is unforgeable and its measurement faithfully reflects the executed binary and configuration (A6); the approved quantizer binary has been deemed acceptable out-of-band (A7)—a TEE proves an approved quantizer *ran on committed inputs*, not that its algorithm is correct. These delimit the residual attestation architecture only; we prove no TEE security theorem.

a) Security-claim boundary, by regime: Against a *cheating quantizer* (W benign, $Q \neq \mathcal{T}(\bar{X}; E)$) we state no single unconditional "detectable": (i) when $B_{\mathcal{E}'}{=}0$ over the rebuilders' environments (the target state), any $Q \neq \mathcal{T}(\bar{X}; E)$ is *soundly detectable* by exact re-derivation; (ii) when $B_{\mathcal{E}'}{>}0$ (the current ecosystem), re-derivation alone cannot decide; for uniformly placed nibble flips we give the *measured detection floor* of §VI, which ranges from 0.02% to 0.2% of Q4_K weights over the environment pairs we measured; a uniform scale perturbation is caught before it is harmful, adaptive placement hides a bounded low-magnitude reservoir, and a targeted embedding edit evades the statistic entirely (§VI), so the statistic is a characterization, not a guarantee; (iii) a *malicious* W (adversarial-fp16, $Q = \mathcal{T}(\bar{X}; E)$) is *not* detectable by re-derivation (A1), since the quantization is honest and re-derivation reproduces it. We deliberately establish how far the no-trusted-hardware approach reaches before invoking attestation.